

ZAP by Checkmarx Scanning Report

Generated with  [The ZAP logoZAP](#) on Tue 6 May 2025, at 09:19:50

ZAP Version: 2.16.1

ZAP by [Checkmarx](#)

Contents

1. [About this report](#)
 1. [Report parameters](#)
2. [Summaries](#)
 1. [Alert counts by risk and confidence](#)
 2. [Alert counts by site and risk](#)
 3. [Alert counts by alert type](#)
3. [Alerts](#)
 1. [Risk=High, Confidence=High \(3\)](#)
 2. [Risk=High, Confidence=Medium \(4\)](#)
 3. [Risk=High, Confidence=Low \(1\)](#)
 4. [Risk=Medium, Confidence=High \(2\)](#)
 5. [Risk=Medium, Confidence=Medium \(4\)](#)
 6. [Risk=Medium, Confidence=Low \(1\)](#)
 7. [Risk=Low, Confidence=High \(1\)](#)
 8. [Risk=Low, Confidence=Medium \(7\)](#)
 9. [Risk=Low, Confidence=Low \(1\)](#)
 10. [Risk=Informational, Confidence=High \(1\)](#)
 11. [Risk=Informational, Confidence=Medium \(4\)](#)
 12. [Risk=Informational, Confidence=Low \(2\)](#)
4. [Appendix](#)
 1. [Alert types](#)

About this report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://php.testinvicti.com>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				Total
Risk		User Confirmed	High	Medium	Low	
	High	0 (0.0%)	3 (9.7%)	4 (12.9%)	1 (3.2%)	8 (25.8%)

	Confidence				
	User Confirmed	High	Medium	Low	Total
Medium	0 (0.0%)	2 (6.5%)	4 (12.9%)	1 (3.2%)	7 (22.6%)
Low	0 (0.0%)	1 (3.2%)	7 (22.6%)	1 (3.2%)	9 (29.0%)
Informational	0 (0.0%)	1 (3.2%)	4 (12.9%)	2 (6.5%)	7 (22.6%)
Total	0 (0.0%)	7 (22.6%)	19 (61.3%)	5 (16.1%)	31 (100%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Site		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://php.testinvicti.com	8 (8)	7 (15)	9 (24)	7 (31)

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting (DOM Based)	High	10 (32.3%)
Total		31

Alert type	Risk	Count
<u>Cross Site Scripting (Reflected)</u>	High	9 (29.0%)
<u>Path Traversal</u>	High	2 (6.5%)
<u>Remote OS Command Injection</u>	High	1 (3.2%)
<u>SQL Injection - SQLite</u>	High	1 (3.2%)
<u>Server Side Include</u>	High	1 (3.2%)
<u>Server Side Template Injection</u>	High	1 (3.2%)
<u>XPath Injection</u>	High	1 (3.2%)
<u>Absence of Anti-CSRF Tokens</u>	Medium	12 (38.7%)
<u>Application Error Disclosure</u>	Medium	13 (41.9%)
<u>Content Security Policy (CSP) Header Not Set</u>	Medium	139 (448.4%)
<u>Directory Browsing</u>	Medium	11 (35.5%)
<u>Hidden File Found</u>	Medium	1 (3.2%)
<u>Missing Anti-clickjacking Header</u>	Medium	122 (393.5%)
<u>XSLT Injection</u>	Medium	1 (3.2%)
<u>Big Redirect Detected (Potential Sensitive Information Leak)</u>	Low	4 (12.9%)
<u>Cookie No HttpOnly Flag</u>	Low	2 (6.5%)
<u>Cookie without SameSite Attribute</u>	Low	2 (6.5%)
Total		31

Alert type	Risk	Count
<u>Information Disclosure - Debug Error Messages</u>	Low	1 (3.2%)
<u>Private IP Disclosure</u>	Low	24 (77.4%)
<u>Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)</u>	Low	119 (383.9%)
<u>Server Leaks Version Information via "Server" HTTP Response Header Field</u>	Low	192 (619.4%)
<u>Timestamp Disclosure - Unix</u>	Low	36 (116.1%)
<u>X-Content-Type-Options Header Missing</u>	Low	167 (538.7%)
<u>Authentication Request Identified</u>	Informational	15 (48.4%)
<u>GET for POST</u>	Informational	1 (3.2%)
<u>Information Disclosure - Suspicious Comments</u>	Informational	8 (25.8%)
<u>Modern Web Application</u>	Informational	82 (264.5%)
<u>Session Management Response Identified</u>	Informational	59 (190.3%)
<u>User Agent Fuzzer</u>	Informational	96 (309.7%)
<u>User Controllable HTML Element Attribute (Potential XSS)</u>	Informational	6 (19.4%)
Total		31

Alerts

1. Risk=High, Confidence=High (3)

1. <http://php.testinvicti.com> (3)

1. [Cross Site Scripting \(DOM Based\)](#) (1)

1. ► POST http://php.testinvicti.com/nslookup.php#jaVasCript:/*-/*`/\*\`/*!/*"/**/(/* */oNcliCk=alert(5397))/%0D%0A%0d%0a//</stYle/</titLe/</teXtarEa/</scRipt/--!>\x3csVg/<sVg/oNloAd=alert(5397)//>\x3e

2. [Server Side Template Injection](#) (1)

1. ► GET http://php.testinvicti.com/artist.php?id=zj%7B%7B5588*5999%7D%7Dzj

3. [XPath Injection](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php?=%22%27

2. **Risk=High, Confidence=Medium (4)**

1. **http://php.testinvicti.com (4)**

1. [Cross Site Scripting \(Reflected\)](#) (1)

1. ► GET http://php.testinvicti.com/artist.php?id=%3C%2Fh3%3E%3CscriPt%3Ealert%281%29%3B%3C%2FscriPt%3E%3Ch3%3E

2. [Remote OS Command Injection](#) (1)

1. ► POST http://php.testinvicti.com/nslookup.php

3. [SQL Injection - SQLite](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php?=PHPE9568F35-D428-11d2-A769-00AA001ACF42

4. [Server Side Include](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php?=%3C%21--%23EXEC+cmd%3D%22dir+%5C%22--%3E

3. **Risk=High, Confidence=Low (1)**

1. **http://php.testinvicti.com (1)**

1. [Path Traversal](#) (1)

1. ► GET http://php.testinvicti.com/hello.php?name=%2Fhello.php

4. Risk=Medium, Confidence=High (2)

1. http://php.testinvicti.com (2)

1. [Content Security Policy \(CSP\) Header Not Set](#) (1)

1. ► GET http://php.testinvicti.com/sitemap.xml

2. [Hidden File Found](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php

5. Risk=Medium, Confidence=Medium (4)

1. http://php.testinvicti.com (4)

1. [Application Error Disclosure](#) (1)

1. ► GET http://php.testinvicti.com/hello.php?name=Visitor

2. [Directory Browsing](#) (1)

1. ► GET http://php.testinvicti.com/auth/images/

3. [Missing Anti-clickjacking Header](#) (1)

1. ► GET http://php.testinvicti.com/auth/login.php

4. [XSLT Injection](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php?=%3Cxsl%3Avalue-of+select%3D%22system-property%28%27xsl%3Avendor%27%29%22%2F%3E

6. Risk=Medium, Confidence=Low (1)

1. http://php.testinvicti.com (1)**1. [Absence of Anti-CSRF Tokens](#) (1)**

1. ► GET http://php.testinvicti.com/auth/login.php

7. Risk=Low, Confidence=High (1)**1. http://php.testinvicti.com (1)****1. [Server Leaks Version Information via "Server" HTTP Response Header Field](#) (1)**

1. ► GET http://php.testinvicti.com/robots.txt

8. Risk=Low, Confidence=Medium (7)**1. http://php.testinvicti.com (7)****1. [Big Redirect Detected \(Potential Sensitive Information Leak\)](#) (1)**

1. ► GET http://php.testinvicti.com/Generics

2. [Cookie No HttpOnly Flag](#) (1)

1. ► GET http://php.testinvicti.com/auth/login.php

3. [Cookie without SameSite Attribute](#) (1)

1. ► GET http://php.testinvicti.com/auth/login.php

4. [Information Disclosure - Debug Error Messages](#) (1)

1. ► GET http://php.testinvicti.com/process.php?file=Generics/about.nsp

5. [Private IP Disclosure](#) (1)

1. ► POST http://php.testinvicti.com/nslookup.php

6. [Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#) (1)

1. ► GET http://php.testinvicti.com/auth/login.php

7. [X-Content-Type-Options Header Missing](#) (1)

1. ► GET http://php.testinvicti.com/robots.txt

9. Risk=Low, Confidence=Low (1)

1. [http://php.testinvicti.com](#) (1)

1. [Timestamp Disclosure - Unix](#) (1)

1. ► GET http://php.testinvicti.com/phpinfo.php

10. Risk=Informational, Confidence=High (1)

1. [http://php.testinvicti.com](#) (1)

1. [GET for POST](#) (1)

1. ► GET http://php.testinvicti.com/nslookup.php

11. Risk=Informational, Confidence=Medium (4)

1. [http://php.testinvicti.com](#) (4)

1. [Information Disclosure - Suspicious Comments](#) (1)

1. ► GET http://php.testinvicti.com/process.php?file=Generics/index.nsp

2. [Modern Web Application](#) (1)

1. ► GET http://php.testinvicti.com/auth/login.php

3. [Session Management Response Identified](#) (1)

1. ► GET <http://php.testinvicti.com/auth/login.php>

4. [User Agent Fuzzer](#) (1)

1. ► GET <http://php.testinvicti.com/auth/>

12. **Risk=Informational, Confidence=Low** (2)

1. <http://php.testinvicti.com> (2)

1. [Authentication Request Identified](#) (1)

1. ► POST <http://php.testinvicti.com/auth/control.php>

2. [User Controllable HTML Element Attribute \(Potential XSS\)](#) (1)

1. ► GET <http://php.testinvicti.com/products.php?pro=url>

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

1. **Cross Site Scripting (DOM Based)**

Source raised by an active scanner ([Cross Site Scripting \(DOM Based\)](#))

CWE ID [79](#)

WASC ID 8

Reference

1. <https://owasp.org/www-community/attacks/xss/>
2. <https://cwe.mitre.org/data/definitions/79.html>

2. **Cross Site Scripting (Reflected)**

Source raised by an active scanner ([Cross Site Scripting \(Reflected\)](#))

CWE ID [79](#)

WASC ID 8

- Reference**
1. <https://owasp.org/www-community/attacks/xss/>
 2. <https://cwe.mitre.org/data/definitions/79.html>

3. Path Traversal

Source raised by an active scanner ([Path Traversal](#))

CWE ID [22](#)

WASC ID 33

- Reference**
1. https://owasp.org/www-community/attacks/Path_Traversal
 2. <https://cwe.mitre.org/data/definitions/22.html>

4. Remote OS Command Injection

Source raised by an active scanner ([Remote OS Command Injection](#))

CWE ID [78](#)

WASC ID 31

- Reference**
1. <https://cwe.mitre.org/data/definitions/78.html>
 2. https://owasp.org/www-community/attacks/Command_Injection

5. SQL Injection - SQLite

Source raised by an active scanner ([SQL Injection - SQLite](#))

CWE ID [89](#)

WASC ID 19

- Reference**
1. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

6. Server Side Include

Source raised by an active scanner ([Server Side Include](#))

CWE ID [97](#)

WASC ID 31

- Reference**
1. <https://httpd.apache.org/docs/current/howto/ssi.html>

7. Server Side Template Injection

Source raised by an active scanner ([Server Side Template Injection](#))

CWE ID [1336](#)

WASC ID 20

Reference 1. <https://portswigger.net/blog/server-side-template-injection>

8. XPath Injection

Source raised by an active scanner ([XPath Injection](#))

CWE ID [643](#)

WASC ID 39

Reference 1. https://owasp.org/www-community/attacks/XPATH_Injection
2. https://owasp.org/www-community/attacks/Blind_XPath_Injection
3. <https://cwe.mitre.org/data/definitions/643.html>

9. Absence of Anti-CSRF Tokens

Source raised by a passive scanner ([Absence of Anti-CSRF Tokens](#))

CWE ID [352](#)

WASC ID 9

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
2. <https://cwe.mitre.org/data/definitions/352.html>

10. Application Error Disclosure

Source raised by a passive scanner ([Application Error Disclosure](#))

CWE ID [550](#)

WASC ID 13

11. Content Security Policy (CSP) Header Not Set

Source raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

CWE ID [693](#)

WASC ID 15

Reference 1. https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy
2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

3. <https://www.w3.org/TR/CSP/>
4. <https://w3c.github.io/webappsec-csp/>
5. <https://web.dev/articles/csp>
6. <https://caniuse.com/#feat=contentsecuritypolicy>
7. <https://content-security-policy.com/>

12. Directory Browsing

Source raised by a passive scanner ([Directory Browsing](#))

CWE ID [548](#)

WASC ID 16

Reference 1. <https://cwe.mitre.org/data/definitions/548.html>

13. Hidden File Found

Source raised by an active scanner ([Hidden File Finder](#))

CWE ID [538](#)

WASC ID 13

Reference 1. <https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html>
2. <https://www.php.net/manual/en/function.phpinfo.php>

14. Missing Anti-clickjacking Header

Source raised by a passive scanner ([Anti-clickjacking Header](#))

CWE ID [1021](#)

WASC ID 15

Reference 1. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

15. XSLT Injection

Source raised by an active scanner ([XSLT Injection](#))

CWE ID [91](#)

WASC ID 23

Reference 1. <https://www.contextis.com/blog/xslt-server-side-injection-attacks>

16. Big Redirect Detected (Potential Sensitive Information Leak)

Source raised by a passive scanner ([Big Redirect Detected \(Potential Sensitive Information Leak\)](#))

CWE ID [201](#)

WASC ID 13

17. Cookie No HttpOnly Flag

Source raised by a passive scanner ([Cookie No HttpOnly Flag](#))

CWE ID [1004](#)

WASC ID 13

Reference 1. <https://owasp.org/www-community/HttpOnly>

18. Cookie without SameSite Attribute

Source raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID [1275](#)

WASC ID 13

Reference 1. <https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site>

19. Information Disclosure - Debug Error Messages

Source raised by a passive scanner ([Information Disclosure - Debug Error Messages](#))

CWE ID [1295](#)

WASC ID 13

20. Private IP Disclosure

Source raised by a passive scanner ([Private IP Disclosure](#))

CWE ID [497](#)

WASC ID 13

Reference 1. <https://tools.ietf.org/html/rfc1918>

21. Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source raised by a passive scanner ([Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#))

CWE ID [497](#)

WASC ID 13

- Reference**
1. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
 2. <https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html>

22. Server Leaks Version Information via "Server" HTTP Response Header Field

Source raised by a passive scanner ([HTTP Server Response Header](#))

CWE ID [497](#)

WASC ID 13

- Reference**
1. <https://httpd.apache.org/docs/current/mod/core.html#servertokens>
 2. [https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552\(v=pandp.10\)](https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10))
 3. <https://www.troyhunt.com/shhh-dont-let-your-response-headers/>

23. Timestamp Disclosure - Unix

Source raised by a passive scanner ([Timestamp Disclosure](#))

CWE ID [497](#)

WASC ID 13

- Reference**
1. <https://cwe.mitre.org/data/definitions/200.html>

24. X-Content-Type-Options Header Missing

Source raised by a passive scanner ([X-Content-Type-Options Header Missing](#))

CWE ID [693](#)

WASC ID 15

- Reference**
1. [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
 2. <https://owasp.org/www-community/Security-Headers>

25. Authentication Request Identified

Source raised by a passive scanner ([Authentication Request Identified](#))

Reference 1. <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/>

26. GET for POST

Source raised by an active scanner ([GET for POST](#))

CWE ID [16](#)

WASC ID 20

27. Information Disclosure - Suspicious Comments

Source raised by a passive scanner ([Information Disclosure - Suspicious Comments](#))

CWE ID [615](#)

WASC ID 13

28. Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

29. Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

Reference 1. <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id>

30. User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

Reference 1. <https://owasp.org/wstg>

31. User Controllable HTML Element Attribute (Potential XSS)

Source raised by a passive scanner ([User Controllable HTML Element Attribute \(Potential XSS\)](#))

CWE ID [20](#)

WASC ID 20

Reference 1. https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html